VULNERABILITY ASSESSMENT REPORT

VULNERABILITY ASSESSMENT REPORT

Authorized Live Web Application (Anonymized)

Target Application	FUTURE_CS_01 (Anonymized)
Assessment Type	Passive / Read-Only
Assessment Date	April 27, 2026
Prepared By	Dhanuja K S E
Classification	**CONFIDENTIAL**

Tools Used: Nmap | OWASP ZAP (Passive) | Browser DevTools | Manual Header Review

1. Executive Summary

A passive vulnerability assessment was conducted on an authorized live web application using non-intrusive and read-only techniques. The objective was to identify publicly observable weaknesses related to security headers, cookie controls, exposed services, and client-side dependencies.

No critical vulnerabilities were identified during the review. The overall security posture was stable, with HTTPS enforced and normal public web services available. Several medium and low risk findings were observed, primarily involving configuration hardening opportunities.

The recommended next step is to implement the listed remediation actions to align the application with modern web security best practices.

0 Critical/High	2 Medium	2 Low	3 Positive Observations

2. Scope & Rules of Engagement

Item	Details
Target	Authorized Live Web Application (Anonymized) — Repository: FUTURE_CS_01
Assessment Type	Passive / Read-Only
In Scope	HTTP response headers, cookie attributes, public port exposure, passive automated scanning, source code observation
Out of Scope	Exploitation attempts, authentication bypass, brute force, Denial-of-Service, destructive testing
Tools Used	Nmap, OWASP ZAP (Passive), Browser DevTools

Testing Period	April 27, 2026

3. Methodology

The assessment followed a structured passive evaluation process. No active exploitation, authentication bypass, or destructive testing was performed at any stage.

Phases

- Information Gathering — Public asset enumeration and header review
- Header Inspection — HTTP response header analysis via Browser DevTools
- Passive Vulnerability Scanning — Automated passive scan using OWASP ZAP
- Network Exposure Review — Port and service enumeration via Nmap
- Manual Validation — Manual review and risk classification of findings
- Remediation Planning — Based on business impact and exploitability

Tools

- Nmap — Network port and service scanning
- OWASP ZAP (Passive Mode) — Automated web vulnerability scanner (read-only)
- Browser DevTools — HTTP header and response analysis

4. Detailed Findings

Each finding below was identified through passive testing techniques. No active exploitation was attempted. Findings are classified according to their potential business and security impact.

ID	Title	Severity	Status
FC-01	Missing Content-Security-Policy (CSP)	Medium	Open
FC-02	Missing X-Frame-Options	Medium	Open
FC-03	Cookie Flags Not Fully Hardened	Low	Open
FC-04	Technology Disclosure in Headers	Informational	Open
FC-05	Third-Party Script Dependency	Low	Open

FC-01 — Missing Content-Security-Policy (CSP)	
Finding ID	FC-01
Severity	Medium
Status	Open
Description	The application does not implement a Content-Security-Policy (CSP) HTTP response header. CSP defines which sources of scripts, styles, images, and other resources the browser should consider trusted.
Risk	Without CSP, the application has reduced protection against client-side injection attacks such as Cross-Site Scripting (XSS), malicious script injection, and unauthorized resource loading.
Business Impact	Increased risk of browser-side compromise. Potential theft of session tokens or user data. Reduced trust if malicious content is injected into the application.

Evidence	No Content-Security-Policy header was observed in HTTP responses during assessment.
Recommendation	`Content-Security-Policy: default-src 'self'; script-src 'self'; style-src 'self';`

FC-02 — Missing X-Frame-Options	
Finding ID	FC-02
Severity	Medium
Status	Open
Description	The application does not set an X-Frame-Options header, leaving it susceptible to being embedded in iframes on third-party domains.
Risk	Clickjacking attacks may allow an attacker to overlay transparent UI elements on top of the application, tricking users into unintended interactions.
Business Impact	Potential clickjacking exposure. Unauthorized UI redressing on external sites. Erosion of user trust if the application is embedded maliciously.
Evidence	No X-Frame-Options header was observed in HTTP response headers during assessment.
Recommendation	`X-Frame-Options: DENY` or `X-Frame-Options: SAMEORIGIN`

FC-03 — Cookie Flags Not Fully Hardened	
Finding ID	FC-03
Severity	Low
Status	Open
Description	Session or functional cookies observed during the assessment were not fully configured with recommended security attributes including Secure, HttpOnly, and SameSite.
Risk	Without these flags, cookies may be exposed via non-HTTPS connections, accessible to client-side scripts, or transmitted in cross-site requests unintentionally.
Business Impact	Reduced session protection. Increased risk of session hijacking or cross-site request forgery depending on application logic.
Evidence	Cookie attribute inspection via Browser DevTools revealed missing or partial flag implementation.
Recommendation	`Enable Secure, HttpOnly, and SameSite=Strict (or Lax) on all session-related cookies.`

FC-04 — Technology Disclosure in Headers	
Finding ID	FC-04
Severity	Informational
Status	Open
Description	HTTP response headers disclose platform and framework identifiers that are not necessary for the application to function. This includes server software and hosting platform banners.
Risk	Technology disclosure enables attackers to profile the environment more efficiently, reducing reconnaissance effort required for targeted attacks.

Business Impact	Increased reconnaissance value for potential attackers. Technology stack exposure without operational necessity.
Evidence	Server and platform identifiers were present in HTTP response metadata during passive review.
Recommendation	`Suppress or customize server identification headers where the hosting platform permits. Remove verbose version strings.`

FC-05 — Third-Party Script Dependency	
Finding ID	FC-05
Severity	Low
Status	Open
Description	The application loads external scripts or resources from third-party domains outside its own origin. These resources are not directly controlled by the application owner.
Risk	External dependencies introduce supply-chain risk, availability risk, and indirect security exposure should any third-party resource be compromised or tampered with.
Business Impact	Dependency outages may affect application functionality. External resource compromise may impact end users. Reduced control over content loaded within the application.
Evidence	Multiple external script references were observed during passive request monitoring and source code review.
Recommendation	`Review all external dependencies. Remove unused resources. Apply Subresource Integrity (SRI) where applicable.`

5. Risk Summary

Severity	Count	Finding IDs
Critical	0	—
High	0	—
Medium	2	FC-01, FC-02
Low	2	FC-03, FC-05
Informational	1	FC-04

Positive Security Observations

Observation	Detail
HTTPS Enabled	All traffic served over encrypted HTTPS — transport-layer protection confirmed.
No Critical Issues	No critical vulnerabilities observed during passive review.
Minimal Attack Surface	Public exposure limited to expected standard web services.

6. Recommendations Roadmap

Immediate Priority (0–7 Days)

ID	Action	Priority
FC-01	Implement Content Security Policy (CSP) header	**High Priority**
FC-02	Set X-Frame-Options to DENY or SAMEORIGIN	**High Priority**

Short Term (1–2 Weeks)

- FC-03 — Harden cookie attributes: enable Secure, HttpOnly, and SameSite flags
- FC-04 — Minimize server and platform information in HTTP response headers
- FC-05 — Review and audit third-party script dependencies; apply SRI where applicable

Ongoing

- Conduct periodic passive security assessments
- Monitor third-party dependencies for known vulnerabilities
- Review security header configurations following any platform or framework updates

7. Conclusion

The assessed web application demonstrates a functional baseline security posture with no critical weaknesses identified through passive testing. Security can be materially improved through configuration hardening and routine maintenance.

Implementing the recommended remediations — particularly the Content Security Policy and X-Frame-Options headers — will meaningfully improve the platform's resilience against client-side threats and align it with current industry security standards.

Continued investment in periodic security reviews and dependency monitoring will support a maturing security posture over time. This report is anonymized for responsible disclosure and public portfolio use.

8. Appendix

Tool Versions

- Nmap — Network port and service scanner (https://nmap.org)
- OWASP ZAP — Passive web application security scanner (https://zaproxy.org)
- Browser DevTools — Native browser developer tools for header inspection

References

- OWASP Secure Headers Project — https://owasp.org/www-project-secure-headers/
- Mozilla Web Security Guidelines — https://infosec.mozilla.org/guidelines/web_security
- Content Security Policy Reference — https://content-security-policy.com/
- X-Frame-Options Reference — https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options

Evidence Screenshots

Attach supporting screenshots below. Replace each placeholder with your captured evidence from Browser DevTools, OWASP ZAP, or Nmap output.

History | Search | Alerts | Output | Spider | AJAX Spider | Active Scan

- Alerts (9)
  - Content Security Policy (CSP) Header Not Set (2)
  - Cross-Domain Misconfiguration (5)
  - Missing Anti-clickjacking Header (2)
  - Timestamp Disclosure - Unix (Systemic)
  - X-Content-Type-Options Header Missing (5)
  - Modern Web Application (2)
  - Re-examine Cache-control Directives
  - Retrieved from Cache (5)
  - User Agent Fuzzer (Systemic)

Full details of any selected alert will be displayed here.

You can manually add alerts by right clicking on the relevant line in the history anc

You can also edit existing alerts by double clicking on them.

Name

- data:image/svg+xml;...
- UcC73FwrK3iLTeHuS_nVMr...
- webConfig
- favicon.png
- jizBRFtNs2ka5fXjeivQ4LroW...
- js?l=dataLayer&id=G-PLCR...
- js.js
- dom.js
- js.js
- dom.js
- html
- data:image/png;base...
- data:image/png;base...
- collect?v=2&tid=G-PLCR8B...
- js.js

Headers | Payload | Preview | Response | Initiator | Timing

Access-Control-Allow-Headers	Cache-Control
Access-Control-Allow-Origin	*
Alt-Svc	h3=":443"; ma=2592000,h3-29=":443"; ma=2592000
Cache-Control	private, max-age=900
Content-Encoding	zstd
Content-Length	146200
Content-Type	application/javascript; charset=UTF-8
Cross-Origin-Resource-Policy	cross-origin
Date	Mon, 27 Apr 2026 06:26:22 GMT
Expires	Mon, 27 Apr 2026 06:26:22 GMT
Server	Google Tag Manager
Vary	Accept-Encoding
X-Xss-Protection	0

Command Prompt

```
Microsoft Windows [Version 10.0.26200.8246]
(c) Microsoft Corporation. All rights reserved.

C:\Users\Dhanuja>nmap -F [redacted].vercel.app
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-27 11:59 +0530
Nmap scan report for cyberbase-nine.vercel.app (64.29.17.67)
Host is up (0.078s latency).
Other addresses for [redacted].vercel.app (not scanned): 216.198.79.67 64:ff9b::d8c6:4f43 64:ff9b::401d:1143
Not shown: 98 filtered tcp ports (no-response)
PORT    STATE SERVICE
80/tcp  open  http
443/tcp open  https

Nmap done: 1 IP address (1 host up) scanned in 4.18 seconds

C:\Users\Dhanuja>
```